Objective

Evaluate how a selected configuration affects expected server operation and a specific access method. This week's pilot examined disabling SSH password authentication while preserving SSH key access.

The broader project asks whether selected CIS hardening recommendations disrupt intended workloads and what measurable security benefit accompanies those changes. This pilot establishes the testing method; it does not establish full CIS compliance.

Work completed

- ☒ prepared the Ubuntu server and reported the initial setup working.
- ☒ created the initial VM snapshot.
- ☒ inspected the SSH authentication settings.
- ☒ attempted direct root SSH access; access was denied before the experimental change.
- ☒ confirmed user password authentication worked.
- ☒ confirmed user key authentication initially failed.
- ☒ installed an authorized public key and confirmed key authentication worked.
- ☒ applied the pilot change, PasswordAuthentication no.
- ☒ confirmed password-only SSH failed after the change.
- ☒ confirmed key-only SSH still worked after the change.
- ☐ confirm that the recommended baseline-key-ready snapshot was created.
- ☐ record post-change sudo and HTTP results.
- ☐ Preserve command output and relevant server logs outside the VM before any rollback.

Field	Record
Experiment ID	SSH-01
Platform	Ubuntu Server 24.04 LTS VM in Proxmox; record installed release/kernel below
VM name / ID	[Fill in]
Starting snapshot	[Exact snapshot name and timestamp]
Preparation change	Installed an authorized public key for the existing administrator account
Experimental change	`PasswordAuthentication yes` to `PasswordAuthentication no`

Field	Record
Configuration file used	`/etc/ssh/sshd_config.d/00-lab-password-auth.conf`
Legitimate workflow	Remote administrator login and use of `sudo`
Security behavior tested	Acceptance or rejection of the SSH password authentication method
CIS benchmark version / profile / recommendation	Pending verification against the benchmark used for the study
Evidence location	[Workstation folder / repository path]

Key enrollment was preparation, not the experimental variable. The appropriate comparison is between the key-ready baseline and that same configuration with password authentication disabled. Preserve the original password-dependent state separately.

Test	Original state	Key-ready baseline	After password authentication disabled
Ordinary-user password-only SSH	Succeeded	Succeeded before change; retain evidence	Denied
Ordinary-user key-only SSH	Failed	Succeeded	Succeeded
Direct root key login	Denied	Not retested	Not retested
`sudo` in a new key-authenticated session	Not separately recorded	Not separately recorded	Pending
HTTP response and expected page content	Setup reported working	Not separately recorded	Pending
Keyboard-interactive authentication	Not tested	Not tested	Pending

These entries summarize reported observations. Raw transcripts, exact timestamps, and exit statuses were not supplied in the conversation; collect them during a documented repeat rather than inventing them retrospectively.

Interpretation

Disabling SSH password authentication prevented the tested password-only connection while preserving the tested key-only connection. The original administrative workflow depended on passwords, so key enrollment was a prerequisite for retaining remote access through this change. The observed operational cost was a change in authentication workflow. Setup time, support effort, application availability, and post-change administrative capability have not yet been quantified. The security conclusion is limited to the tested authentication method. No brute-force campaign, CVE exploitation, compromise-rate measurement, or complete attack chain was performed. Root access already failed before the change, so that failure is not evidence of benefit from this experiment. Keyboard-interactive authentication is a separate mechanism that still needs checking.

Remaining questions and next milestone

- Which exact CIS benchmark version, profile, and recommendation applies? Verify before labeling SSH-01 a CIS recommendation evaluation.
- Does any legitimate script or administrative process require password authentication?
- How much time did key enrollment and workflow migration require? Record future measurements rather than estimating missing past timings.
- Can the result be reproduced from the key-ready snapshot with the same account, client, packages, and network path?

Next milestone: repeat the baseline/post-change comparison from a known snapshot, collecting the same tests and raw evidence in both conditions. A later security scenario can explicitly assume an attacker has a valid password but no authorized key; distinguish that scenario from password guessing and from a general claim that the server cannot be compromised.

This week's category is temporary-filesystem hardening, starting with noexec on /tmp. It gives you a more substantial experiment: application behavior, software maintenance, attacker execution, and whether a workaround preserves the protection.

Use Ansible to automatically harden the server according to level 2: CIS Hardening playbook